Enterprise Zero Trust Security Architecture

HL-CYB-001 | Four-week cybersecurity engineering assignment

1. Project Overview

Purple Eye, a fictional organization, needs an analyst to read reports, an engineer to read maintenance instructions and an unassigned user to be denied access. A separate administrator manages the lab.

Use an isolated lab to demonstrate these access decisions, remote access and application recovery with synthetic people and data. Apply Zero Trust: check identity and permission for each resource; network membership alone grants no access. Submit evidence showing what works, what fails and any limits.

2. Learning Objectives

- Verify a prepared lab, protect administration and enforce network boundaries.
- Manage Windows identities and distinguish standard from privileged permissions.
- Enforce application roles, trusted HTTPS and narrow Tailscale access; revoke access.
- Investigate security events, repeat one small automation safely and restore an encrypted backup in isolation.
- Test the results and explain them through clear evidence and a final presentation.

3. Lab Environment

Use the existing **Dell Precision 5820 with Proxmox VE**, **HP desktop with physical OPNsense**, **TP-Link TL-SG108E managed switch** and **GL.iNet Beryl AX upstream router**. OPNsense provides physical firewall routing; the Dell hosts exactly three workload virtual machines (VMs):

- **DC1, Corporate:** Windows Server with Active Directory (AD), Domain Name System (DNS) and Group Policy; 2 vCPU / 6 GiB RAM / 64 GiB disk.
- **WIN1, Corporate:** Windows client; 2 vCPU / 6 GiB RAM / 64 GiB disk.
- **APP1, Restricted:** Linux with Apache serving the HTTPS application; 2 vCPU / 4 GiB RAM / 32 GiB disk.

The guest allocation totals **6 vCPU / 16 GiB RAM / 160 GiB virtual disks**. Physical OPNsense is separate from these totals. The Architecture owns the detailed capacity model; allocations do not prove available capacity. See the glossary for terms.

Three logical security zones are required: **Management** for restricted administration, **Corporate** for DC1 and WIN1, and **Restricted** for APP1. The wider home lab's six-zone/VLAN design is optional.

Verify the prepared environment before dependent work:

- Confirm Proxmox and physical OPNsense are accessible to the authorized administrator, with console recovery available.
- Confirm the three security boundaries, restricted management and sufficient resources for the three workloads, host reserves and temporary restore.
- Demonstrate home/production isolation and verify required network flows and denials using configuration inspection and lab-owned mock targets.
- Record current data and services, backup and recovery readiness; preserve the original Windows disk, data and services.

Resolve readiness gaps with the owner before continuing.

Safety: use separate lab identities, credentials and synthetic data. No home/production trust, synchronization, credential reuse, corporate Microsoft 365 connection, PE-DAP code, customer data, corporate website testing or hosting integration is permitted. Keep uplinks disconnected until independent isolation and egress receive owner approval. Inspect protected networks passively; never probe them. Each implementation stage requires explicit owner approval covering changes, validation and rollback; follow the Lab Implementation Guide.

4. Project Activities

Plan for four weeks at 8-12 focused hours weekly after readiness approval: verify the environment; configure identity and endpoints; secure application and remote access; then investigate events, automate, restore and validate. Use the guide for procedures and approvals. Extra workload VMs, mandatory extra zones, enterprise single sign-on, high availability and additional remote providers are outside scope.

Create three synthetic standard users, three role groups and one separate privileged administrator. AD manages Windows accounts. The application uses separate test accounts, distinct passwords and manually assigned roles. Removing an application role must deny further access; an AD change alone is insufficient. Demonstrate all six application cases and revocation of existing and fresh requests.

FWR labels a requirement; FWT labels its matching test. Complete every mandatory subcheck and keep these IDs in the answer sheets.

ID	Required result	Test
FWR-01	Keep lab networks, trust, credentials and data separate from home and production; verify isolation by configuration review and a lab-owned mock boundary.	FWT-01
FWR-02	Verify the prepared Dell/Proxmox host, physical HP/OPNsense firewall, three workload VMs and three zones; deny unlisted flows, restrict administration, retain console recovery and confirm measured capacity fits.	FWT-02
FWR-03	Create separate AD with three standard users, three role groups and one privileged admin. Pass six application allow/deny cases and revoke access.	FWT-03
FWR-04	Use supported Windows and Linux systems, enabled host firewalls, recorded updates and separate standard-user and administrator rights.	FWT-04
FWR-05	Sign one HTTPS application certificate with one CA; verify hostname, trust, validity and untrusted-client rejection.	FWT-05

ID	Required result	Test
FWR-06	Allow lab-only Tailscale access solely to app.ad.lab.test over HTTPS. Demonstrate permitted, denied and revoked access.	FWT-06
FWR-07	Record five security events from two or three relevant log sources and investigate one denied-access event.	FWT-07
FWR-08	Complete one useful PowerShell or Python operation. Repeat it safely with no unintended changes.	FWT-08
FWR-09	Restore the agreed application scope from one encrypted backup stored away from the host; record actual recovery time, data checks and exclusions.	FWT-09
FWR-10	Link requirements and tests to reviewed evidence; submit files and sanitized GitHub work. Separate engineering verification from owner acceptance.	FWT-10

Use one certificate authority (CA) to sign the APP1 HTTPS certificate. Restrict Tailscale to APP1 HTTPS only, without subnet routes, exit nodes or public sharing. Collect five event categories: directory logon success and failure, application allow and deny, and firewall denial. Use the guide's local-capacity summary as the single automation. Restore APP1 once into a disconnected segment, preserving the original and backup with copied Tailscale inactive; verify data, HTTPS and roles and measure elapsed recovery time.

5. Required Deliverables

The five files are available as blank templates in the deliverable library. Complete them during approved lab work. Keep working copies and raw evidence private; submit reviewed summaries under `docs/deliverables/`.

Filename	What to record
01-Lab-Environment-and-Architecture.xlsx	Readiness, topology, capacity and flows (FWR-01, FWR-02).
02-Identity-and-Zero-Trust-Implementation.docx	Accounts, endpoints, roles, HTTPS and Tailscale (FWR-03, FWR-04, FWR-05, FWR-06).
03-Security-Monitoring-and-Testing.xlsx	Events, investigation, tests, automation and restore (FWR-07, FWR-08, FWR-09, FWR-10).
04-Troubleshooting-and-Lessons.xlsx	Problems, diagnosis, fixes, retests and lessons (FWR-10).
05-Final-Project-Submission.docx	Results, evidence, rubric, limits and acceptance (FWR-10).

6. Evaluation Rubric

Assessment area	Points	Evidence for full credit
Infrastructure and Network Security	25	Prepared-environment verification, three-zone segmentation, restricted management, correct network permissions and isolation evidence.
Identity and Access Controls	25	AD and endpoint controls, six role cases, access revocation, HTTPS and restricted Tailscale.
Security Monitoring and Operations	20	Five events, one explained denial and safely repeatable automation.
Testing and Recovery	20	Complete test records, second observations and a successful restore with measured limits.
Documentation and Final Submission	10	Five clear submissions, traceable sanitized evidence and accurate results and limitations.

Total: 100 points.

Grade demonstrated results, not plans alone. All mandatory subchecks must pass. Support each denial with a working allowed control and a separate policy or log observation. Critical isolation or security failures block acceptance regardless of score.

7. Completion Criteria

- Meet all ten requirements and every mandatory subcheck of FWT-01 through FWT-10, supported by actual results, evidence and second observations. Record failures and unexecuted checks honestly in the answer sheets.
- Resolve critical/high safety issues and document remaining limitations, troubleshooting and recovery scope. A documentation check alone does not demonstrate a working lab.
- Submit the five completed files and reviewed, sanitized GitHub artifacts. Keep credentials, actual addresses, private inventories, raw logs and backups outside the public repository.
- Present the access decisions, security investigation, automation and isolated recovery results, with links to their evidence.
- Record engineering verification separately from the owner's explicit user acceptance testing (UAT) decision, following the Acceptance Criteria.